# CO-2 ASSESSMENT-1

## SIMATS ENGINEERING

## ASSESSMENT TOOL 1 – ETHICAL HACKING

### REPORT ANALYSIS

This report analyzes an Nmap network scan, a GoPhish phishing-awareness campaign, and a DNS zone-transfer assessment. The answers cover report interpretation, security risks, practical countermeasures, and conclusions aligned with the assessment rubric.

Ethical-use note: Perform security testing only on systems and accounts for which explicit authorization has been granted. Add actual lab evidence if required by your faculty.

### Q1. Nmap Network Scan Report Analysis

**Aim**

To analyze the Nmap report for target 192.168.1.10, identify risks associated with open ports and detected services, explain possible attack methods, and recommend security measures.

**Introduction**

Nmap (Network Mapper) is a network discovery and security auditing tool used to identify hosts, open ports, running services, service versions, and possible operating-system details. The report identifies port 22 (SSH), port 80 (HTTP), and port 3306 (MySQL). An open port is not automatically a vulnerability; risk depends on exposure, software version, configuration, and access controls.

**Analysis of identified services**

**A. Port 22 – SSH (Secure Shell)**

Purpose: SSH provides encrypted remote administration.

Security risks:

- Weak, reused, or leaked passwords may permit unauthorized login attempts.
- Outdated SSH software may contain known vulnerabilities.
- Password authentication may be targeted by brute-force or password-spraying attempts.
- Incorrect permissions or excessive privileges increase the impact of a compromised account.

Possible attacker approach: A reachable SSH service may be targeted with guessed or leaked credentials. If an account is compromised, an attacker may access resources permitted to that account. A vulnerable version may present further risk, but the scan alone does not prove exploitability.

Countermeasures:

1. Use strong, unique credentials and preferably SSH key-based authentication.
2. Disable direct root login and unnecessary password authentication where appropriate.
3. Patch the SSH server and operating system.
4. Restrict SSH access to trusted administrator IP addresses or a VPN.
5. Enable MFA where supported, rate-limit repeated attempts, and monitor authentication logs.
6. Apply least privilege to administrator accounts.

**B. Port 80 – HTTP**

Purpose: HTTP delivers web pages and application content. HTTP traffic itself is not encrypted.

Security risks:

- Data sent over HTTP may be intercepted by an attacker with a suitable network position.
- Credentials or session information may be exposed if sent without adequate protection.
- Outdated web servers or applications may contain known vulnerabilities.
- Weak input validation may lead to SQL injection or cross-site scripting.
- Directory listings, default pages, or unnecessary modules may reveal information.

Possible attacker approach: An attacker may observe unencrypted traffic or probe a web application for weaknesses. If an exploitable flaw exists, it could

cause data exposure or unauthorized actions. Impact depends on the application and configuration.

Countermeasures:

7. Configure HTTPS with valid TLS certificates and redirect HTTP to HTTPS.
8. Update the web server, frameworks, and application components.
9. Validate input and use parameterized database queries.
10. Disable directory listing, default pages, and unused modules.
11. Apply secure session management and suitable security headers.
12. Use a web application firewall where appropriate and review web logs.

**C. Port 3306 – MySQL**

Purpose: MySQL is a relational database management system used to store and retrieve application data.

Security risks:

- Database exposure to untrusted networks increases unauthorized-access risk.
- Weak or default credentials may permit access.
- Excessive database permissions can magnify the impact of account compromise.
- Outdated database versions may contain known vulnerabilities.
- Misconfiguration may expose confidential customer or business information.

Possible attacker approach: A reachable database may be targeted using weak or leaked credentials. If access is obtained, an attacker may read or modify data according to the account's privileges. A highly privileged account creates greater potential impact.

Countermeasures:

13. Avoid exposing MySQL directly to the public internet unless strictly required and securely controlled.
14. Restrict access through firewalls, private networks, and approved application hosts.
15. Use strong credentials and remove default or unused accounts.
16. Apply least privilege to database accounts.
17. Patch MySQL and review its configuration regularly.

18. Use TLS for database connections and protect sensitive data with access controls.
19. Maintain secure backups and test recovery procedures.

**Overall risk assessment**

| Port / Service | Main concern | Priority recommendation |
|---|---|---|
| 22 / SSH | Remote login abuse or vulnerable software | Restrict source IPs, harden authentication, patch, and monitor |
| 80 / HTTP | Unencrypted traffic and web application weaknesses | Use HTTPS, patch applications, validate inputs, and review logs |
| 3306 / MySQL | Unauthorized database access or data exposure | Restrict network access, use least privilege, patch, and encrypt connections |

MySQL deserves particular attention if reachable from networks that do not need database access. Final prioritization should be based on business need, actual network exposure, service versions, and verified vulnerabilities.

**Result**

The report identifies SSH, HTTP, and MySQL services. Misconfiguration, weak authentication, outdated software, or unnecessary exposure can create security risks. Service hardening, patching, network restrictions, encryption, monitoring, and least privilege reduce those risks.

## Q2. GoPhish Phishing Awareness Campaign Analysis

### Aim

To interpret the phishing-awareness campaign at ABC Technologies Pvt. Ltd., identify employee security weaknesses, and recommend user training, email controls, and organizational policies.

### Introduction

GoPhish is a platform used by authorized security teams to run controlled phishing-awareness simulations. In this scenario, 40% clicked the phishing link, 20% entered credentials, and several users downloaded a malicious attachment. These results suggest that employee awareness and technical email protections need improvement.

### Interpretation of campaign findings

| Finding | Interpretation | Security significance |
|---|---|---|
| 40% clicked the link | A substantial proportion interacted with the message | Link verification and phishing recognition may be inconsistent |
| 20% entered credentials | Some employees submitted sensitive information | Possible account compromise and unauthorized access |
| Several downloaded an attachment | Users handled a potentially unsafe file | Possible malware or endpoint risk, depending on file behavior and controls |

Interpret percentages using the campaign's recipient count and measurement definitions. Clicking does not prove compromise, and downloading an attachment does not prove that malware executed. These results identify behavior requiring follow-up.

**Security weaknesses demonstrated**

- Insufficient recognition of urgency, suspicious links, unexpected attachments, and sender impersonation.
- Over-trust in messages that appear to come from IT or another trusted department.
- Failure to verify links and requests through an independent channel.
- Unsafe credential handling by entering details into a page reached through an unexpected message.
- Potentially unsafe attachment-handling practices.
- Possible gaps in reporting suspicious emails promptly.

**User awareness programs**

20. Conduct regular short training on phishing, spear-phishing, impersonation, malicious attachments, and credential theft.
21. Run authorized phishing simulations and provide immediate, supportive feedback.
22. Teach employees to check the full sender address, inspect links carefully, and avoid unexpected attachments.
23. Encourage verification of urgent requests through the official help desk or another trusted channel.
24. Provide a simple Report Phishing button or clear reporting address.
25. Offer role-specific training for finance, HR, IT support, and privileged users.
26. Measure improvement through click rates, credential-submission rates, reporting rates, and repeat interactions.

Training should be educational rather than punitive. Employees should feel safe reporting mistakes quickly so security staff can respond before damage spreads.

**Email security controls**

| Control | How it reduces risk |
|---|---|
| SPF, DKIM, and DMARC | Help authenticate legitimate domain email and reduce domain spoofing. |
| Secure email gateway | Filters known phishing messages, suspicious URLs, and unsafe attachments. |

| | |
|---|---|
| URL and attachment analysis | Can identify malicious links or files before interaction. |
| Sandboxing | Allows suspicious attachments to be examined in an isolated environment where supported. |
| Multi-factor authentication (MFA) | Adds a layer beyond passwords, though ordinary MFA can still be phished in some attacks. |
| Phishing-resistant MFA | Passkeys or security keys provide stronger protection against credential-phishing attacks. |
| Endpoint protection and patching | Can detect or limit malicious activity and reduce vulnerable software exposure. |
| Least privilege | Limits what a compromised user or device can access. |

**Organizational policies**

27. Create an email-security policy explaining how to handle unexpected messages and attachments.
28. Require independent verification for password, payment, account-reset, and sensitive-data requests.
29. Define a clear process for reporting phishing and suspected credential exposure.
30. Maintain an incident-response plan for isolating devices, resetting credentials, revoking sessions, and investigating activity.
31. Use least privilege and review access to sensitive systems regularly.
32. Patch operating systems, browsers, office applications, and endpoint tools.
33. Protect employee privacy during simulations and use campaign data responsibly.
34. Review campaign metrics and adapt training and controls based on results.

**Response after a click, credential submission, or attachment download**

35. Report the event immediately to IT or the security team.
36. If credentials were entered, change the password through the official portal and follow security-team instructions.
37. Revoke active sessions and review sign-in activity if compromise is suspected.
38. If an attachment was opened or executed, follow incident-response instructions; the security team may isolate the device for examination.
39. Preserve the suspicious message and relevant evidence.
40. Apply broader containment steps if investigation identifies a wider campaign or compromise.

**Measuring improvement**

Compare campaigns over time using consistent definitions and recipient counts. Useful measures include click rate, credential-submission rate, reporting rate, repeat interaction rate, and time taken to report. Improvement should mean fewer risky interactions and more timely reporting.

The 20% credential-submission result deserves particular attention because entering credentials can expose accounts. Attachment interactions should also be investigated to determine whether files executed or triggered security alerts.

**Result**

The campaign indicates weaknesses in phishing recognition, link verification, credential handling, and attachment safety. Awareness training, email authentication and filtering, MFA, endpoint protection, clear reporting procedures, and incident-response planning can reduce social engineering risk.

## Q3. DNS Zone Transfer Assessment Using dig

**Aim**

To analyze a DNS report showing a successful AXFR zone transfer, explain the security implications of exposed records, and recommend best practices for securing DNS infrastructure.

## Introduction

DNS translates domain names into IP addresses and stores service-related records. AXFR is a legitimate mechanism for copying DNS zone data between authorized DNS servers. If a server permits an unauthorized requester to transfer a zone, hostnames, mail servers, and other DNS records may be disclosed.

## Report interpretation

The report states that a zone transfer succeeded. This means the requester received DNS zone records. If the requester was unauthorized, this indicates an access-control weakness. A successful transfer alone does not prove that the listed hosts are vulnerable or compromised.

| Record type | Meaning | Possible exposure |
|---|---|---|
| A / AAAA | Maps hostnames to IPv4 / IPv6 addresses | Hostnames and associated IP addresses |
| MX | Identifies mail servers | Email infrastructure |
| CNAME | Aliases one hostname to another | Relationships between hostnames |
| NS | Identifies authoritative nameservers | DNS administration structure |
| TXT | Stores text data such as email-security policies | Policy or domain-verification information |
| SOA | Contains zone-administration information | DNS configuration details |

## Security implications and possible attacker use

- Host discovery: records may reveal hostnames and addresses associated with systems and services.
- Mail infrastructure discovery: MX records may show which mail servers handle the organization's email, helping plan targeted phishing.

- Subdomain enumeration: records may reveal web, VPN, testing, development, or other service names for further review.
- Infrastructure mapping: relationships between records may help an attacker understand the public-facing environment.
- More efficient reconnaissance: the requester may obtain many hostnames without discovering them individually.

The main issue is information disclosure. A listed hostname is not necessarily internal or reachable from the internet. The organization should validate records against its asset inventory.

**Best practices to secure DNS infrastructure**

41. Restrict AXFR to explicitly authorized secondary DNS servers using server configuration and access-control lists.
42. Use TSIG authentication for zone transfers where supported and properly configured.
43. Verify that unauthorized transfer requests are refused.
44. Audit DNS records regularly and remove obsolete, unnecessary, or incorrect entries.
45. Monitor and log zone-transfer requests and investigate unexpected attempts.
46. Separate internal DNS zones from public DNS where appropriate; avoid publishing internal-only names in public zones.
47. Keep DNS software updated and restrict administrative access.
48. Maintain a documented DNS inventory, change-control process, and incident-response procedure.

**Result**

The successful AXFR result indicates that DNS zone information was transferred. If the requester was unauthorized, the configuration may disclose hostnames, mail servers, and other records that support reconnaissance. Restricting transfers, using TSIG where supported, auditing records, monitoring requests, and separating internal and public DNS data help reduce this risk.

**Overall Conclusion**

The reports identify risks in network-service exposure, employee responses to phishing, and DNS configuration. SSH, HTTP, and MySQL should be hardened according to their business purpose; phishing results should guide training and

email-security improvements; and unauthorized DNS zone transfers should be prevented. Regular patching, least privilege, strong authentication, monitoring, secure configuration, and incident-response planning provide layered protection.

**Code of Conduct**

I, _____J.Vishnu Vardhan(192324297)_____
(Name / Reg No), certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: _____vishnu_____

Date: _____21/10/26_____

**Rubric Alignment Checklist**

| **Rubric criterion** | **Weightage** | **How the report addresses it** |
|---|---|---|
| Report Analysis and Interpretation | 25% | Explains the meaning and significance of Nmap, GoPhish, and DNS AXFR findings. |
| Identification of Security Risks and Vulnerabilities | 25% | Identifies service exposure, weak authentication, phishing behavior, attachment risks, and DNS information disclosure. |
| Application of Cybersecurity Concepts and Countermeasures | 30% | Recommends hardening, email controls, awareness training, access restrictions, |

| | | |
|---|---|---|
| | | monitoring, and incident response. |
| Technical Communication and Documentation | 20% | Uses structured headings, tables, terminology, and clear conclusions. |

Before submission: Add your name and register number. Include actual screenshots or supporting evidence if required, and ensure that any reported findings match the scenario or your authorized lab results.